

Laboratorio di Internet
Relazione III:
Comando NMAP

Gruppo 5
Davide Caramagna, 285019



Aprile 2024 - AA 2023/2024
Prof. Bianco Andrea

1 Configurazione di rete

IP H1	10.0.5.1/25
IP H2	10.0.5.2/25
Netmask	255.255.255.128
Indirizzo di rete	10.0.5.0
Indirizzo broadcast	10.0.5.127

Su ogni terminale sono stati attivati i servizi "echo" e "chargin" attraverso modifiche al file "/etc/inetd.conf" ed uil riavvio da linea di comando del processo generato dal file "/etc/init.d/openbsd-inetd". Questi servizi utilizzano rispettivamente la porta 7 (servizio "echo") e la porta 19 (servizio "chargin").

2 Obiettivo e metodologie del test

L'obiettivo di questa consegna è utilizzare il comando "nmap" per scansionare quali porte sono aperte sulle macchine collegate alla medesima sotto-rete. In particolare i cinque comandi analizzati sono:

- nmap 10.0.5.2 -p 7,99
- sudo nmap 10.0.5.2 -p 7,99
- sudo nmap 10.0.5.2 -p 7,99 -O
- sudo nmap 10.0.5.2 -p 1-100
- sudo nmap 10.0.5.2 -p 1-100 -sU

L'opzione "-p 7,99" esplicita la decisione di controllare solamente le porte 7 e 99, mentre "-p 1-100" richiede l'analisi delle porte da 1 a 100. L'opzione "-O" è necessaria per il riconoscimento del sistema operativo attaccato e "-sU" analizza le porte su cui appoggia un servizio UDP.

Per l'analisi dei dati si è optato uno script bash che ha in input un file .csv che é frutto dell'esportazione dei dati ottenuti con wireshark.

3 Risultati ottenuti

3.1 Utilizzo dei privilegi super user

La differenza tra i comandi "nmap 10.0.5.2 -p 7,99" e "sudo nmap 10.0.5.2 -p 7,99" si può vedere dall'analisi dei pacchetti scambiati tra le due macchine grazie al software wireshark: nel primo caso vengono contattate preventivamente le porte 80 (utilizzata da HTTP) e 443 (utilizzata da HTTPS) e solo successivamente si controllano le porte richieste dall'utente (Figura 1), al contrario con i privilegi super user si controllano direttamente le porte specificate (Figura 2). Ciò è dovuto alle caratteristiche intrinseche del comando "nmap", come esplicitato nella documentazione. Inoltre, attraverso i privilegi sudo si può notare come i pacchetti che vengono inviati siano pacchetti raw (Figura 3), ovvero pacchetti di cui nmap può decidere l'intero contenuto (intestazioni comprese): nmap apre la connessione con pacchetti di tipo "SYN" e, nel caso in cui la porta puntata risponda, tronca la conversazione immediatamente con pacchetti di tipo "TCP RST". Questa tipologia di analisi è definita come "SYN SCAN". Al contrario quando viene eseguito il comando senza i privilegi sudo l'analisi eseguita è di tipo "TCP connect scan", ovvero viene aperta e chiusa regolarmente la connessione. È facilmente intuibile come la "SYN SCAN" sia molto più efficiente della "TCP connect scan" dalla mole di pacchetti scambiati.

3.2 Rilevamento del sistema operativo

Il comando sudo nmap 10.0.5.2 -p 7,99 -O è il comando che consente la rilevazione del sistema operativo attraverso l'impronta che il sistema lascia quando invia un pacchetto. Il comando esegue in automatico numerosi test che mirano non solo a riconoscere il sistema operativo utilizzato ma anche il tipo di macchina, il produttore ed altre informazioni sensibili che possono essere codificate attraverso degli standard intrinsechi alla costruzione del pacchetto internet.

Le porte scelte per eseguire questi controlli sono casuali, questo grazie all'utilizzo dei permessi concessi da sudo, che consentono al programma di scrivere ogni bit dentro il pacchetto e di conseguenza scegliere quale porta utilizzare per l'invio.

Wireshark ci mostra alcuni di questi pacchetti: Figura 4.

3.3 UDP vs TCP

I comandi utilizzati per la seguente analisi sono stati: "sudo nmap 10.0.5.2 -p 1-100" (o la sua variante esplicita "sudo nmap 10.0.5.2 -p 1-100 -sS") e "sudo nmap 10.0.5.2 -p 1-100 -sU".

Entrambi i comandi scansionano in modo randomico tutte le porte da 1 a 100 su cui appoggiano le applicazioni che utilizzano TCP, nel primo caso, o UDP, nel secondo (se si fosse voluto optare per una scansione lineare delle porte si sarebbe potuto aggiungere "-r"). Si è notato che in questa situazione (legato ai permessi concessi da sudo) nmap per ogni scansione utilizza una porta diversa per eseguire le connessioni. I risultati sono mostrati nella Figura 5.

Si può notare come nel caso di TCP venga analizzata ogni porta una sola volta, mentre nel caso di UDP le medesime porte vengano analizzate più volte. Come si può leggere dalla documentazione di nmap questo comportamento è dovuto alla costruzione stessa del protocollo UDP in quanto ogni porta non necessariamente risponde e questo porta nmap ad attendere il timeout (tempo di attesa della risposta prima di considerare il pacchetto perso o non inviato) prima di tentare di ricontattare la porta. Per classificare come "aperta" o "filtered" (la distinzione richiede ulteriore lavoro e tempo impiegato) una porta UDP è necessario che questa o non risponda (caso più frequente, stando alla documentazione) o che risponda con un pacchetto UDP, il che costringe nmap a scansionare più volte la medesima porta (ciò spiega il comportamento che wireshark mostra): tutto ciò non fa che rallentare l'analisi. Un'ulteriore limitazione della scansione UDP è legata al sistema operativo che si sta utilizzando: per poter classificare una porta come "closed" è necessario che nmap riceva un pacchetto "ICMP error" (con codici 0, 1, 2, 3, 9, 10, 13), ma l'invio di questi pacchetti è limitato nella quantità per unità di tempo da alcuni sistemi operativi (come Linux e Solaris) per evitare l'exploit di porte lasciate non protette e rallentare le scansioni.

I risultati sono rappresentati graficamente in Figura 6.

4 Appendice

No.	Time	Source	Destination	Protocol	Length	Info
7	47.089447955	10.0.5.1	10.0.5.2	TCP	74	60090 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 T...
8	47.089518984	10.0.5.1	10.0.5.2	TCP	74	47654 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 T...
9	47.089908768	10.0.5.2	10.0.5.1	TCP	60	80 → 60090 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
10	47.089999745	10.0.5.2	10.0.5.1	TCP	60	443 → 47654 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
11	47.091451031	10.0.5.1	10.0.5.2	TCP	74	49326 → 99 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 T...
12	47.091479777	10.0.5.1	10.0.5.2	TCP	74	38010 → 7 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TS...
13	47.091841206	10.0.5.2	10.0.5.1	TCP	60	99 → 49326 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
14	47.091874590	10.0.5.2	10.0.5.1	TCP	74	7 → 38010 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SAC...
15	47.091906089	10.0.5.1	10.0.5.2	TCP	66	38010 → 7 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=2158565116
16	47.091926133	10.0.5.1	10.0.5.2	TCP	66	38010 → 7 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=215856...

Figura 1: Comando nmap 10.0.5.2 -p 7,99

3	0.067969764	10.0.5.1	10.0.5.2	TCP	58	55777 → 99 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4	0.068002149	10.0.5.1	10.0.5.2	TCP	58	55777 → 7 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
5	0.068583577	10.0.5.2	10.0.5.1	TCP	60	99 → 55777 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	0.068584555	10.0.5.2	10.0.5.1	TCP	60	7 → 55777 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
7	0.068661171	10.0.5.1	10.0.5.2	TCP	54	55777 → 7 [RST] Seq=1 Win=0 Len=0

Figura 2: Comando sudo nmap 10.0.5.2 -p 7,99

```

> Ethernet II, Src: LCFCHFe:47:4e:28 (54:e1:ad:47:4e:28), Dst: e8:9c:25:0d:02:ce (e8:9c:25:0d:02:ce)
> Internet Protocol Version 4, Src: 10.0.5.1, Dst: 10.0.5.2
> Transmission Control Protocol, Src Port: 45285, Dst Port: 7, Seq: 1, Len: 0
  Source Port: 45285
  Destination Port: 7
  [Stream index: 5]
  [TCP Segment Len: 0]
  Sequence number: 1 (relative sequence number)
  Sequence number (raw): 3639669474
  [Next sequence number: 1 (relative sequence number)]
  Acknowledgment number: 0
  Acknowledgment number (raw): 0
  0101 .... = Header Length: 20 bytes (5)
  > Flags: 0x004 (RST)
    000. .... = Reserved: Not set
    ...0 .... = Nonce: Not set
    ....0 .... = Congestion Window Reduced (CWR): Not set
    ....0 .... = ECN-Echo: Not set
    ....0 .... = Urgent: Not set
    ....0 .... = Acknowledgment: Not set
    ....0 .... = Push: Not set
    > .....1.. = Reset: Set
    ....0 .... = Syn: Not set
    ....0 .... = Fin: Not set
    [TCP Flags: .....R..]
  Window size value: 0
  [Calculated window size: 0]
  [Window size scaling factor: 1024]
  Checksum: 0x151e [unverified]
  [Checksum Status: Unverified]
  Urgent pointer: 0
  > [Timestamps]
    [Time since first frame in this TCP stream: 0.000612508 seconds]
    [Time since previous frame in this TCP stream: 0.000063695 seconds]

```

Figura 3: Contenuto di un pacchetto mandato da nmap con privilegi sudo

37	0.899199976	10.0.5.1	10.0.5.2	TCP	74 45298 → 7 [ACK] Seq=1 Ack=1 Win=10485/b Len=0 WS=1024 MSS=265...
38	0.899809040	10.0.5.2	10.0.5.1	TCP	60 7 → 45298 [RST] Seq=1 Win=0 Len=0
39	0.914390525	10.0.5.1	10.0.5.2	TCP	74 45299 → 99 [SYN] Seq=0 Win=31337 Len=0 WS=1024 MSS=265 TSval=...
40	0.914960640	10.0.5.2	10.0.5.1	TCP	60 99 → 45299 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
41	0.939655389	10.0.5.1	10.0.5.2	TCP	74 45300 → 99 [ACK] Seq=1 Ack=1 Win=33554432 Len=0 WS=1024 MSS=2...
42	0.940077859	10.0.5.2	10.0.5.1	TCP	60 99 → 45300 [RST] Seq=1 Win=0 Len=0
43	0.964888135	10.0.5.1	10.0.5.2	TCP	74 45301 → 99 [FIN, PSH, URG] Seq=1 Win=1073725440 Urg=0 Len=0 W...
44	0.965283297	10.0.5.2	10.0.5.1	TCP	60 99 → 45301 [RST, ACK] Seq=1 Ack=2 Win=0 Len=0
45	0.990175218	10.0.5.1	10.0.5.2	TCP	74 [TCP Dup ACK 35#1] 45296 → 7 [<None>] Seq=1 Win=131072 Len=0 ...
46	1.015454478	10.0.5.1	10.0.5.2	TCP	74 [TCP Retransmission] 45297 → 7 [FIN, SYN, PSH, URG] Seq=0 Win...
47	1.090355199	10.0.5.1	10.0.5.2	TCP	74 [TCP Dup ACK 35#2] 45296 → 7 [<None>] Seq=1 Win=131072 Len=0 ...
48	1.115695640	10.0.5.1	10.0.5.2	TCP	74 [TCP Retransmission] 45297 → 7 [FIN, SYN, PSH, URG] Seq=0 Win...
49	1.191007237	10.0.5.1	10.0.5.2	TCP	74 [TCP Dup ACK 35#3] 45296 → 7 [<None>] Seq=1 Win=131072 Len=0 ...
50	1.216315132	10.0.5.1	10.0.5.2	TCP	74 [TCP Retransmission] 45297 → 7 [FIN, SYN, PSH, URG] Seq=0 Win...
51	2.382566289	10.0.5.1	10.0.5.2	TCP	74 [TCP Port numbers reused] 45282 → 7 [SYN] Seq=0 Win=1 Len=0 W...
52	2.382937775	10.0.5.2	10.0.5.1	TCP	74 7 → 45282 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SAC...
53	2.383019490	10.0.5.1	10.0.5.2	TCP	54 45282 → 7 [RST] Seq=1 Win=0 Len=0
54	2.482872055	10.0.5.1	10.0.5.2	TCP	74 [TCP Port numbers reused] 45283 → 7 [SYN] Seq=0 Win=63 Len=0 ...
55	2.483449203	10.0.5.2	10.0.5.1	TCP	74 7 → 45283 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SAC...
56	2.483527166	10.0.5.1	10.0.5.2	TCP	54 45283 → 7 [RST] Seq=1 Win=0 Len=0
57	2.583160928	10.0.5.1	10.0.5.2	TCP	74 [TCP Port numbers reused] 45284 → 7 [SYN] Seq=0 Win=4 Len=0 T...
58	2.583692131	10.0.5.2	10.0.5.1	TCP	74 7 → 45284 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 TSV...
59	2.583772588	10.0.5.1	10.0.5.2	TCP	54 45284 → 7 [RST] Seq=1 Win=0 Len=0
60	2.683321832	10.0.5.1	10.0.5.2	TCP	70 [TCP Port numbers reused] 45285 → 7 [SYN] Seq=0 Win=4 Len=0 S...
61	2.683948867	10.0.5.2	10.0.5.1	TCP	74 7 → 45285 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SAC...
62	2.684040080	10.0.5.1	10.0.5.2	TCP	54 45285 → 7 [RST] Seq=1 Win=0 Len=0
63	2.783581432	10.0.5.1	10.0.5.2	TCP	74 [TCP Port numbers reused] 45286 → 7 [SYN] Seq=0 Win=16 Len=0 ...
64	2.784024645	10.0.5.2	10.0.5.1	TCP	74 7 → 45286 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SAC...

Figura 4: Rilevamento del sistema operativo

laboratorio@laboratorio:/\$ sudo nmap 10.0.5.2 -p 1-100	laboratorio@laboratorio:/\$ sudo nmap 10.0.5.2 -p 1-100 -sU
Starting Nmap 7.80 (https://nmap.org) at 2024-04-30 15:12 CEST	Starting Nmap 7.80 (https://nmap.org) at 2024-04-30 15:14 CEST
Nmap scan report for 10.0.5.2	Nmap scan report for 10.0.5.2
Host is up (0.00013s latency).	Host is up (0.00063s latency).
Not shown: 97 closed ports	Not shown: 97 closed ports
PORT STATE SERVICE	PORT STATE SERVICE
7/tcp open echo	7/udp open echo
19/tcp open chargen	19/udp open chargen
37/tcp open time	37/udp open time
MAC Address: E8:9C:25:0D:02:CE (Unknown)	MAC Address: E8:9C:25:0D:02:CE (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds	Nmap done: 1 IP address (1 host up) scanned in 98.66 seconds

Figura 5: Risultati della scansione TCP e UDP

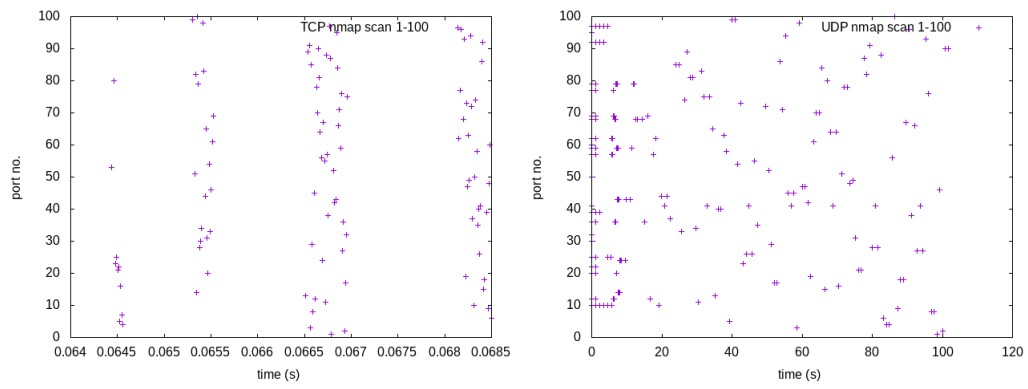


Figura 6: Rappresentazione grafica della scansione TCP e UDP

4.1 Fonti e materiali

Fonti:

- Documentazione di nmap per le opzioni
- Documentazione di nmap per le tipologie di scansione
- Documentazione di nmap per il rilevamento del sistema operativo

Materiali:

- Repository GitHub con materiale codici utilizzati

Per ogni punto il testo è un link alla pagina web referenziata.